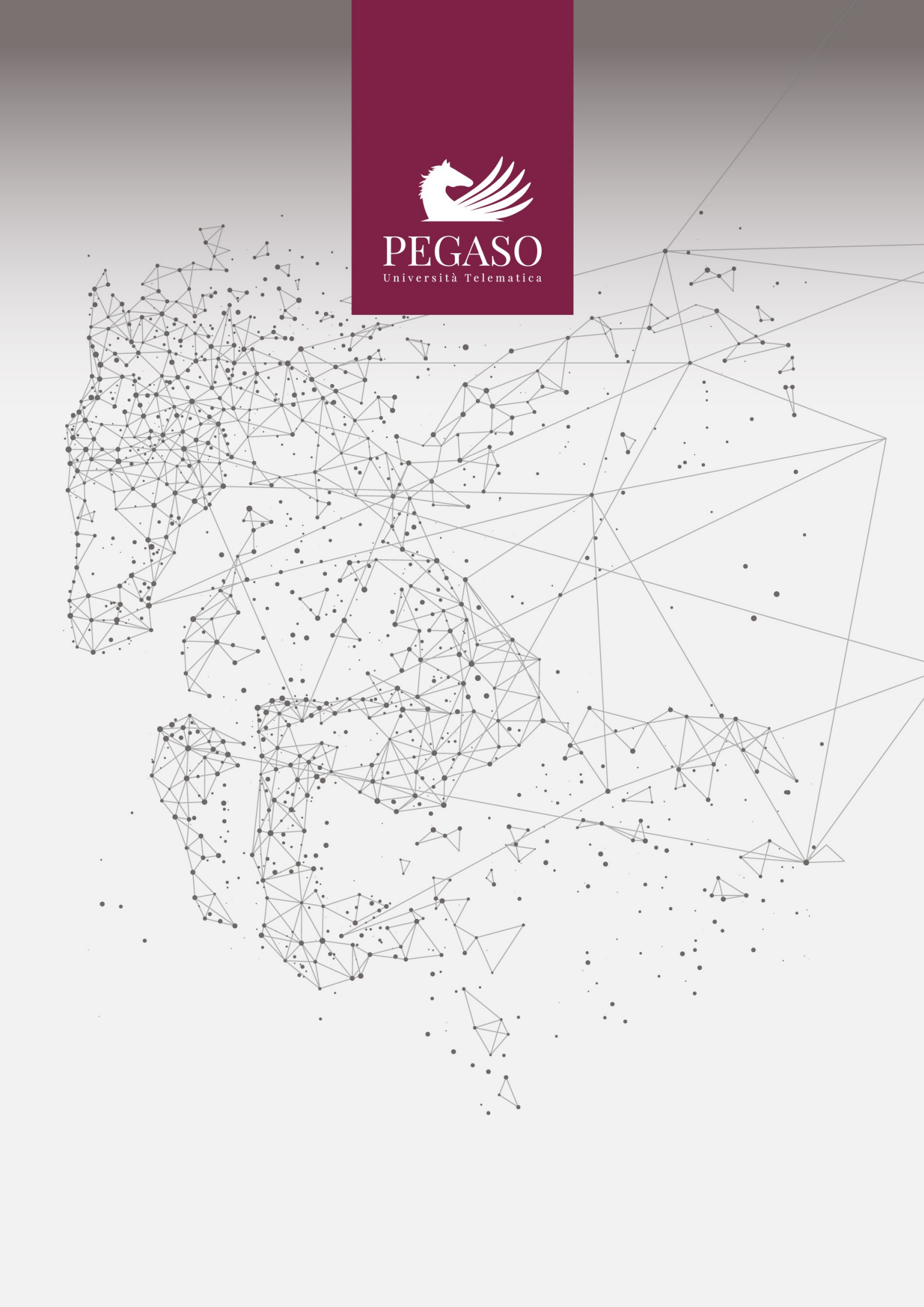

PEGASO
Università Telematica

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1. PANORAMICA SULLA SICUREZZA IP 3
2. ARCHITETTURA E SERVIZI IPSEC 5
3. AUTHENTICATION HEADER (AH) 8
BIBLIOGRAFIA 11

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1. Panoramica sulla sicurezza IP

IPSec costituisce un insieme di funzioni di sicurezza che operano a livello di protocollo IP, quindi in maniera del tutto trasparente rispetto al livello delle applicazioni. IPSec nasce sostanzialmente da due necessità:

- rendere sicura l'infrastruttura di rete da un monitoraggio non autorizzato del traffico
- rendere sicuro il traffico in transito fra gli utenti finali utilizzando meccanismi di autenticazione e crittografia

IPSec contrasta tutti quegli attacchi che avvengono a livello IP (e.g. intercettazione dei pacchetti) come lo *spoofing IP* in cui un estraneo crea pacchetti con indirizzi IP fasulli per by-passare applicazioni che usano l'autenticazione basata su IP.

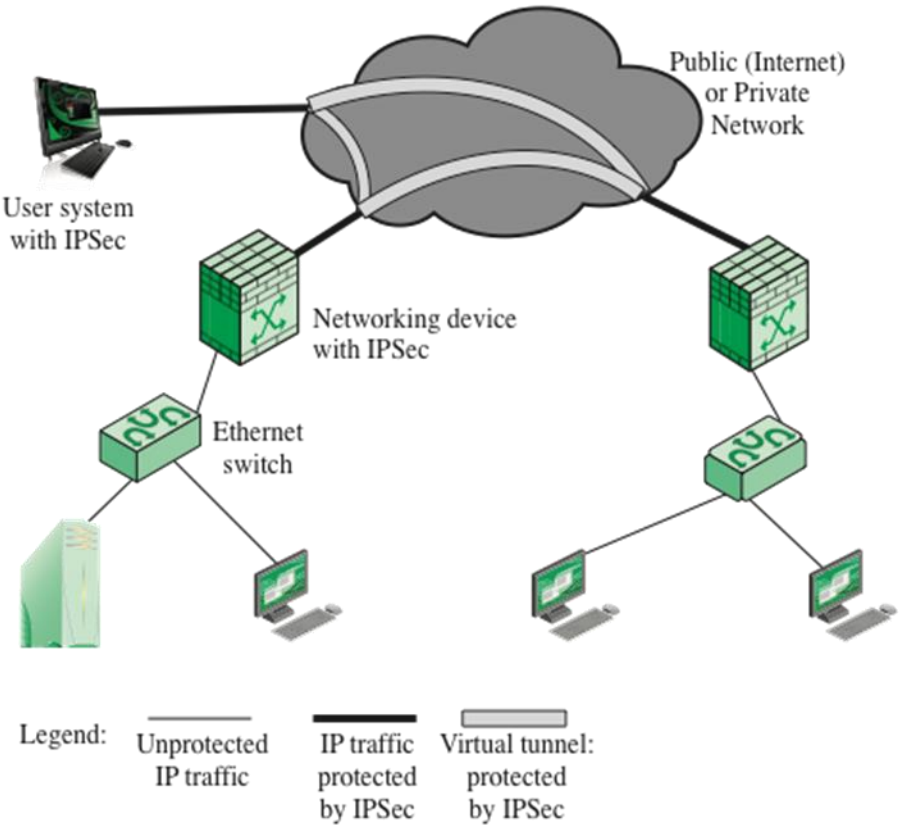
IPSec permette di crittografare e/o autenticare tutto il traffico a livello IP e ciò può essere utilizzato per varie applicazioni:

- realizzare una rete privata (aziendale) virtuale sicura sfruttando Internet (riduzione costi)
- realizzare un accesso remoto sicuro ad una rete aziendale
- realizzare comunicazioni sicure tra diverse aziende

L'uso principale di IPSec è sicuramente quello di realizzare delle VPN (Virtual Private Network) come evidenziato nella figura sottostante in cui si vede come, per esempio, un utente dotato di IPSec possa accedere da remoto attraverso una rete pubblica, come Internet, ad una o più reti aziendali anch'esse protette da IPSec sul loro gateway di ingresso ma non al loro interno.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2. Architettura e servizi IPSec

IPSec fornisce i servizi di sicurezza a livello IP consentendo di selezionare i protocolli, di determinare gli algoritmi da utilizzare e di gestire le chiavi crittografiche. Per garantire la sicurezza vengono impiegati due protocolli basati su degli *extension header* che seguono l'intestazione principale IP:

- un protocollo di autenticazione denominato *Authentication Header (AH)*
- un protocollo combinato di crittografia e autenticazione denominato *Encapsulated Security Payload (ESP)*

I servizi offerti sono i seguenti:

1. *controllo degli accessi*
2. *integrità dei dati con protocolli senza connessione*
3. *autenticazione dell'origine dei dati*
4. *rifiuto dei pacchetti a replay*
5. *segretezza*
6. *segretezza parziale del flusso di traffico*

Il protocollo AH garantisce solo i primi 4 servizi, mentre il protocollo *ESP* non garantisce il 2 e il 3 ma *con l'opzione di autenticazione* garantisce tutta questa serie di servizi.

Un concetto molto importante nei meccanismi di autenticazione e segretezza IP è quello di *associazione di sicurezza (SA – Security Association)*

- *Una SA è una relazione monodirezionale fra un mittente e un destinatario che riguarda i servizi di sicurezza relativi al traffico trasportato*

Se è richiesto uno scambio sicuro bidirezionale sono necessarie due associazioni di sicurezza; ad una SA sono assegnati i servizi di sicurezza secondo i protocolli AH o ESP ma non di entrambi.

Una SA è identificata univocamente da tre parametri che sono:

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- *SPI (Security Parameters Index)*: identifica l'associazione di sicurezza ed è trasportato nelle intestazioni AH e ESP
- *Indirizzo IP di destinazione*: identifica l'indirizzo finale dell'associazione di sicurezza (e.g. l'utente finale, un firewall o un router)
- *Identificatore del protocollo di sicurezza*: identifica se l'associazione di sicurezza è di tipo AH o ESP.

Gli *SPI (Security Parameters Index)* sono i seguenti (alcuni dei principali) e sono definiti in un SAD (Security Association Database):

- *Sequence Number Counter:* valore a 32 bit utilizzato per generare il campo Sequence Number dell'intestazione AH o ESP
- *Anti-Replay window:* utilizzato per determinare se un pacchetto in ingresso è un replay
- *AH information*: algoritmo di autenticazione, chiavi, durata delle chiavi e altri parametri correlati
- *ESP information*: algoritmo di crittografia e autenticazione, chiavi, valori di inizializzazione, durata delle chiavi e parametri relativi
- *Lifetime of this SA*: validità temporale della SA
- *IPSec Protocol Mode*: trasporto, tunnel o wildcard.

AH e ESP supportano due modalità di funzionamento: *trasporto* e *tunnel*.

Nella modalità *trasporto* si realizza la protezione dei protocolli di livello superiore ovvero la protezione riguarda il payload del pacchetto IP

- AH autentica il payload IP e determinate parti dell'intestazione IP
- ESP esegue la crittografia e, opzionalmente, autentica il payload IP

Nella modalità *tunnel* invece si fornisce la protezione dell'intero pacchetto IP; una volta che al pacchetto IP sono stati aggiunti i campi AH o ESP, l'intero pacchetto e i campi di sicurezza vengono trattati come payload del nuovo pacchetto IP con nuova intestazione IP esterna. Il

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

pacchetto originario IP viaggia in una specie di tunnel e nessun router durante il percorso sarà in grado di esaminare l'intestazione IP interna.

- AH autentica l'intero pacchetto IP e determinate parti dell'intestazione IP esterna
- ESP esegue la crittografia e, opzionalmente, autentica l'intero pacchetto IP interno, compresa l'intestazione IP interna

PEGASO
Università Telematica

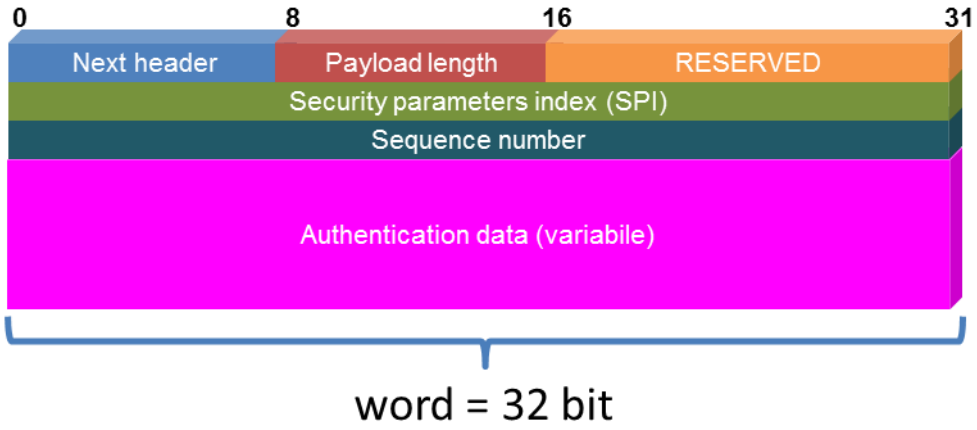
Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3. Authentication Header (AH)

Authentication Header (AH) fornisce il supporto per *l'integrità dei dati* e per *l'autenticazione dei pacchetti IP*. La funzionalità di integrità dei dati garantisce che non sia possibile modificare il contenuto del pacchetto in transito senza che ciò sia rilevato, mentre invece la funzionalità di autenticazione consente a un sistema finale o a un dispositivo di rete di autenticare l'utente o l'applicazione e filtrare il traffico, di conseguenza. Quest'ultima funzionalità è molto importante soprattutto perché impedisce *attacchi IP spoofing* e *attacchi replay*.

L'autenticazione si basa su un codice MAC, pertanto le due parti devono condividere una chiave segreta

Vediamo adesso com'è strutturato l'Authentication Header (AH). Esso è costituito dai campi di seguito elencati ed evidenziati in figura.



- **Next header (8 bit)**: identifica il tipo di intestazione che segue immediatamente questa intestazione
- **Payload length (8 bit)**: lunghezza dell'AH in word meno 2 (praticamente non considera le prime due word di intestazione)
- **Reserved**: campo riservato
- **SPI:** Security Parameters Index identifica un'associazione di sicurezza
- **Sequence Number**: è un contatore incrementale

PEGASO Università Telematica

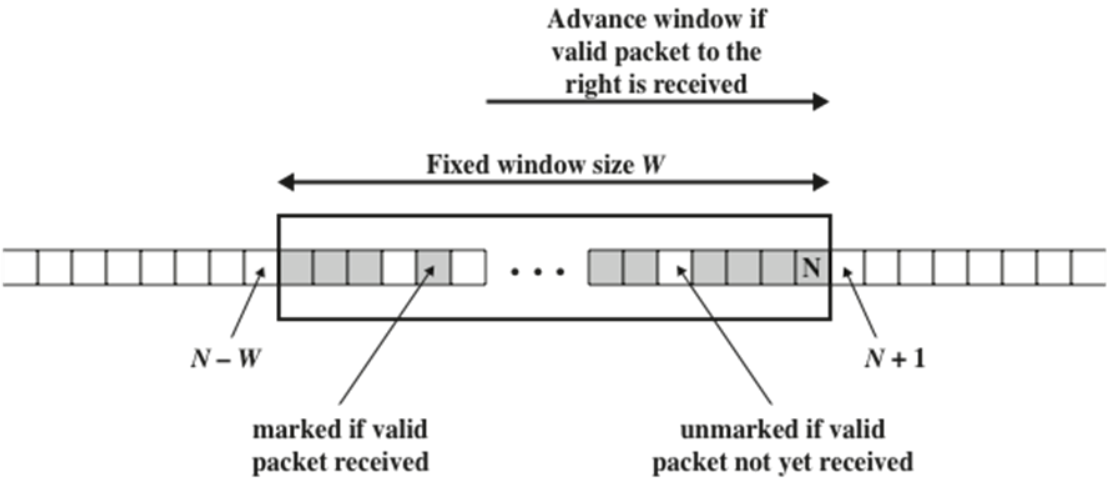
Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- **Authentication Data**: ha una lunghezza variabile in multipli di word e contiene il valore ICV (Integrity Check Value) o MAC

Il campo **Sequence Number** ha lo scopo di impedire *attacchi replay* in cui un attaccante ha ottenuto una copia di un pacchetto autenticato che trasmette successivamente alla destinazione per scopi malevoli

- Il sequence number può assumere valori da 0 a (2^{32}-1) all'interno di una certa SA
- Ogni pacchetto IP inviato incrementa di 1 il contatore del sequence number
- Terminati i 2^{32} valori si deve negoziare una nuova SA

Poiché il protocollo IP offre un servizio senza connessione non affidabile, non garantisce che i pacchetti vengano consegnati in ordine e neanche che siano consegnati. Pertanto, il ricevitore implementa una finestra di dimensioni W=64 e i pacchetti con valore a sinistra della finestra non sono considerati accettabili (vedi figura).



Via via che i pacchetti sono ricevuti, le varie posizioni sono marcate (sempre se i pacchetti sono riconosciuti come validi, ovvero il codice MAC è verificato). Ogni volta che si riceve un pacchetto che sta a destra della finestra, questa viene spostata in avanti; tutti i pacchetti che

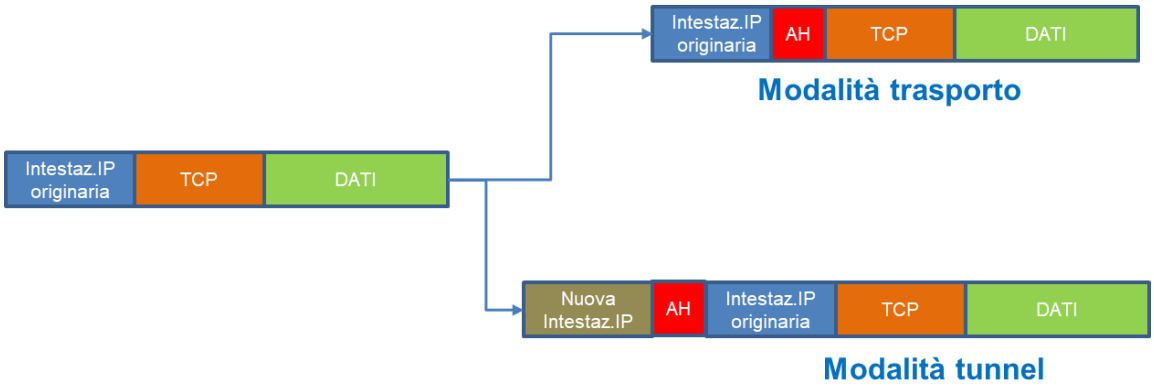
Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

arrivano e cadono a sinistra dell'ultima posizione di finestra sono ritenuti non accettabili (e.g. potenziali pacchetti replay).

Il codice MAC viene calcolato sulla base degli elementi che non cambiano durante la trasmissione altrimenti se variabili vengono posti a 0 per poter fare così gli stessi calcoli all'origine e alla destinazione. Tali campi sono:

- i campi di intestazione IP che sono immutabili (evita IP spoofing!); hanno una struttura diversa nel caso IPv4 e IPv6
- l'intestazione AH tranne il campo Authentication Data che è variabile
- tutti i dati del protocollo di livello superiore che siano immutabili

Nel protocollo AH (per esempio nel caso IPv4) il pacchetto IP originario viene così modificato (vedi figura) nella modalità *trasporto* e *tunnel*:



Nel primo caso (trasporto) l'Authetication Header (AH) viene inserito dopo l'intestazione IP originaria e prima del payload IP (per esempio un segmento TCP); nel secondo caso (tunnel) l'intestazione AH viene inserita fra l'intestazione originaria IP e la nuova intestazione IP esterna. L'intestazione IP interna trasporta gli indirizzi di origine e di destinazione finali mentre quella esterna può contenere indirizzi IP differenti come gli indirizzi dei firewall e di altri gateway di sicurezza.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: Capitoli 16.
- "Cryptography and Network Security", 7/ed, William Stallings, Pearson.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).